

SAPPHIRE B2B

sapphiresc.com

Tarih: 29/04/2026

Konu: Sapphire B2B Platformuna Yönelik Siber Saldırı Tespiti ve İhtar

Muhatap:

A.I.T. Bilgisayar Sistemleri Makine San. ve Tic. Ltd. Şti.

Bursa, Türkiye

Sayın İlgililer,

28-29 Nisan 2026 tarihlerinde sapphiresc.com platformumuza yönelik hedefli, sistematik ve süregelen bir siber saldırı tespit edilmiştir. Bu saldırının kaynağının, şirketinize ait altyapıyla doğrudan ilişkili olduğu teknik delillerle belirlenmiştir.

Bu mektup, tespit edilen bulguları sizinle paylaşmak ve konuya ilişkin açıklama talep etmek amacıyla gönderilmektedir.

1. Tespit Edilen Saldırı Aktiviteleri

Platformumuz üzerinde aşağıdaki yetkisiz erişim ve saldırı vektörleri tespit edilmiştir:

#	Saldırı Vektörü	Detay
1	SSRF (Server-Side Request Forgery)	Eksploit API üzerinden 73+ iç ağ tarama isteği. 18 farklı port tarandı (DB, Redis, Elasticsearch vb.)
2	AWS Metadata Erişimi	169.254.169.254 ve 169.254.170.2 üzerinden sunucu kimlik bilgilerine erişim teşebbüsü
3	Uzaktan Komut Çalıştırma (RCE)	nc -e perl -w // protokolü ile Redis üzerinden Lua io.popen() ile shell komutu çalıştırma denemesi
4	Credit/Kaynak Manipülasyonu	15.100 credit enjeksiyonu — kayıttan 90 saniye sonra
5	Path Traversal	../../../../etc/passwd.png ile sunucu dosyalarına erişim denemesi
6	Stored XSS	SVG dosyasına zararlı JavaScript kodu yerleştirme
7	Phishing	SVG içine sahte giriş formu yerleştirme (veri hırsızlığı amaçlı)
8	Kaynak Kod Okuma	XInclude ile uygulama kaynak kodunu okuma denemesi (file:///app/src/...)
9	Docker Daemon Erişimi	Port 2375/2376/4243 üzerinden konteyner erişim denemesi
10	Admin Brute-force	25+ yetkisiz admin endpoint'e erişim denemesi
11	Kalıcı Erişim (Persistence)	admin scope API key oluşturma + 42 sahte hesap

2. Şirketinizle İlişkilendiren Teknik Deliller

Aşağıdaki teknik bulgular, saldırının şirketinize ait altyapıyla doğrudan bağlantılı olduğunu göstermektedir:

Bulgu	Detay
Saldırgan IP Adresi	84.44.79.182 — Bursa, Türkiye Bu IP adresi, saldırı araçlarının kullanıldığı webhook.site token'ını oluşturan IP olarak üçüncü parti kayıtlarla belgelenmiştir.
Aynı IP'de Çalışan Servisler	84.44.79.182:5000 → 'AI Pattern Generator' HTML meta: og:url = 'https://aitools.ait.com.tr' HTML meta: og:site_name = 'AIT AI-Tools' 84.44.79.182:5001 → AIT logolu 'Archivist' admin paneli
Domain Bağlantısı	aitools.ait.com.tr → ait.com.tr alt alan adı ait.com.tr WHOIS kaydı: A.I.T. BİLGİSAYAR SİSTEMLERİ MAKİNE SAN. VE TİC. LTD. ŞTİ.
Zaman Korelasyonu	Saldırı başlangıcı: 28 Nisan 12:17 UTC AIT sunucusunda uygulama build zamanı: 28 Nisan 13:13 UTC (Vite build timestamp — aynı zaman dilimi)
Parmak İzi	Tüm saldırı oturumlarında aynı araç: curl/8.12.1 6 farklı IP'den (ofis, mobil, Tor) aynı parmak izi
Önceki İletişim	28 Nisan 2026'da saldırıdan kısa süre önce şirketinizden platformumuz hakkında bilgi almak için telefon araması yapılmıştır. (HTS kayıtlarıyla doğrulanabilir)
İkinci IP — Mobil	131.222.238.224 — İstanbul, 4GNET mobil internet Aynı gece saat 20:39'da aynı saldırı araçlarıyla (curl/8.12.1) ikinci webhook token oluşturulmuştur.

3. Erişilen / Keşfedilen Ticari Bilgiler

Saldırgan aşağıdaki ticari sırlarımıza ve altyapı bilgilerimize erişim sağlamış veya erişmeye teşebbüs etmiştir:

Bilgi	Yöntem	Durum
AI desen üretim motorunun kapasitesi	134 desen üretimi	Erişildi
Export pipeline (TIFF/PDF/PSD)	58+ export	Erişildi
8K Upscale AI modeli	6 adet upscale	Erişildi
İç ağ mimarisi (18 port)	SSRF tarama	Kısmen erişildi
Credit/pricing modeli	Manipülasyon	Erişildi
Kaynak kod + altyapı haritası	XInclude + SSRF	Kısmen erişildi
Sunucu kimlik bilgileri	AWS IMDS	Engellendi

4. Alınan Önlemler ve Mevcut Durum

Saldırıya karşı aşağıdaki kapsamlı güvenlik önlemleri alınmıştır:

- Tüm 42+ sahte hesap tespit edilip banlanmıştır

- Tüm saldırı vektörleri (SSRF, XSS, RCE, Path Traversal) kapatılmıştır
- Saldırgan IP adresleri ve Tor ağı engellenmiştir
- Forensic düzeyinde loglama sistemi kurulmuştur — bundan sonraki her erişim girişimi IP, user-agent, payload ve zaman damgasıyla kayıt altına alınmaktadır
- Tüm deliller SHA-256 ile hashlenerek arşivlenmiştir
- Cloudflare'e destek talebi açılmıştır
- Wayback Machine üzerinden saldırının web varlıkları arşivlenmiştir

Platformumuz şu an tam korumalıdır. Güvenlik önlemleri sonrasında saldırının hiçbir API endpoint'ine erişemediği forensic kayıtlarla belgelenmiştir.

5. Toplanan Delil Paketi

Aşağıdaki deliller toplanmış ve mahkemeye sunulmak üzere arşivlenmiştir:

Delil Türü	Adet / İçerik
Sunucu logları (Railway)	48 saatlik tam log + filtrelenmiş saldırı logları
Veritabanı dökümleri	User, Pattern, Credit, ApiKey, SecurityLog tabloları
Webhook.site kayıtları	2 token, 32+ callback, IP-zaman korelasyonu
WHOIS/DNS kayıtları	5 domain, 3 IP geolocation, DNS çözümleme
Saldırgan sunucu snapshot'ları	84.44.79.182 port 5000/5001 HTML, HTTP headers
CDN'deki zararlı dosyalar	SSRF Proof SVG, XSS SVG, Phishing SVG, RCE payload
OSINT araştırması	GitHub profili, AIT/MiraB2B web sayfaları
Cloudflare Dashboard SS'leri	20 adet ekran görüntüsü (canlı, zamanlı)
SHA-256 hash dosyası	92 dosyanın bütünlük doğrulaması

6. Taleplerimiz

Şirketinizden aşağıdaki hususlarda açıklama talep etmekteyiz:

1. 28-29 Nisan 2026 tarihlerinde 84.44.79.182 IP adresinden sapphiresc.com'a yönelik gerçekleştirilen erişimlerin kim tarafından, hangi amaçla yapıldığı
2. Bu erişimlerin şirketiniz bilgisi dahilinde mi yoksa bireysel bir girişim mi olduğu
3. Platformumuzdan elde edilen ticari bilgilerin (desen üretim verileri, export çıktıları, altyapı bilgileri) ne amaçla toplandığı ve nerede kullanıldığı
4. Bu tür erişimlerin derhal durdurulacağına dair yazılı taahhüt

Bu mektuba 7 (yedi) iş günü içinde yazılı yanıt verilmemesi halinde, toplanan deliller savcılığa sunularak TCK 243 (Bilişim Sistemlerine Girme), TCK 244 (Sistemi Engelleme, Bozma, Verileri Yok Etme veya Değiştirme) ve ilgili mevzuat kapsamında yasal işlem başlatılacaktır.

Ayrıca haksız rekabet, ticari sırların ihlali ve kişisel verilerin korunması mevzuatı kapsamında tazminat davası açma hakkımız saklıdır.

Sapphire B2B Platform

sapphiresc.com

Tarih: 29/04/2026 14:14 UTC+3

Bu belge ve ekleri gizlidir. Sadece muhataba yöneliktir.